

Cirque Corporation

Risk Management Policy

Document ID: IS-CIRQ-P-003-G
Category: Base Policy & ISMS Manual
Division: Policy
Type: Global
Version: 1.1
Effective Date: June 2025
Review Date: June 2026
Approved By: Executive Committee
Generated: March 02, 2026

1. Purpose

The purpose of this policy is to establish Cirque's commitment and methodology for identifying, assessing, and treating information security risks in alignment with ISO/IEC 27001:2022 Clause 6.1. This systematic approach ensures that information security risks are managed to an acceptable level, supporting Cirque's business objectives and compliance obligations.

****2. Scope****

2. Scope

This policy applies to all information security risk management activities undertaken within Cirque's Information Security Management System (ISMS) scope, as defined in IS-CIRQ-D-001-G: ISMS Scope Document. It covers all information assets, processes, technologies, and personnel relevant to information security across all Cirque locations and operations.

****3. Principles of Risk Management****

3. Principles of Risk Management

Cirque's approach to information security risk management is based on the following principles:

- ****Systematic and Consistent:**** Risks will be identified, analyzed, evaluated, and treated using a consistent and repeatable methodology, employing ****Low, Medium, and High**** classifications.
- ****Proactive:**** Information security risks will be identified and addressed proactively, rather than reactively, where possible.
- ****Risk-Based Decision Making:**** Decisions regarding information security controls and investments will be based on a clear understanding of identified risks and their potential impact.
- ****Continual Improvement:**** The risk management process will be regularly reviewed and improved.
- ****Transparency:**** Risk management activities and decisions will be documented and communicated to relevant stakeholders.
- ****Top Management Support:**** Top management is committed to providing adequate resources for risk management.

****4. Risk Management Framework****

4. Risk Management Framework

Cirque adopts a structured approach to risk management, encompassing the following phases:

****4.1. Risk Identification**** a. Identify all information assets within the ISMS scope, considering their value to Cirque (e.g., intellectual property, customer data, financial data, manufacturing designs, source

code). b. Identify potential threats to these assets (e.g., cyber-attacks, human error, natural disasters, hardware failure, unauthorized access). c. Identify existing vulnerabilities that could be exploited by threats. d. Identify existing controls and their effectiveness.

****4.2. Risk Analysis**** a. Assess the likelihood of a threat exploiting a vulnerability to cause an information security incident using ****Low, Medium, or High**** qualitative ratings. b. Assess the potential impact (e.g., financial, reputational, legal, operational) of such an incident on Cirque's business objectives using ****Low, Medium, or High**** qualitative ratings. c. Combine likelihood and impact to determine the level of inherent risk (e.g., High, Medium, Low).

****4.3. Risk Evaluation**** a. Compare the assessed risk levels against Cirque's established risk acceptance criteria. b. Prioritize risks based on their severity and alignment with risk acceptance levels.

****4.4. Risk Treatment**** a. Select appropriate risk treatment options based on the risk evaluation: * ****Modify:**** Implement controls to reduce the risk (e.g., encryption, access controls, training). * ****Retain:**** Accept the risk as it falls within acceptable levels or treatment is not cost-effective. * ****Avoid:**** Cease the activity that generates the risk. * ****Share/Transfer:**** Transfer the risk to another party (e.g., insurance, outsourcing with robust contracts). b. Develop and implement a Risk Treatment Plan (IS-CIRQ-D-005-G) detailing the selected controls, responsibilities, and timelines. c. Implement controls from ISO 27001 Annex A as appropriate.

****4.5. Risk Monitoring and Review**** a. Identified risks and the effectiveness of implemented controls will be regularly monitored. b. ****A formal review of high risks will be conducted quarterly.**** c. The

entire risk assessment and treatment processes will be reviewed periodically to ensure their ongoing suitability and effectiveness. d. Risks will be re-evaluated when significant changes occur (e.g., new systems, new business processes, new threats).

****5. Risk Acceptance Criteria****

5. Risk Acceptance Criteria

The Executive Committee will define and approve the criteria for accepting information security risks. Cirque maintains a ****low risk appetite****, aiming to mitigate almost all identified risks, even those initially assessed as minor, where feasible and cost-effective. Risks exceeding the defined acceptance criteria must be treated.

****6. Roles and Responsibilities****

6. Roles and Responsibilities

- ****Executive Committee:**** Approves the Risk Management Policy and Risk Acceptance Criteria.
- ****IT Manager:**** Accountable for the overall risk management process, including facilitating risk assessments, maintaining the Risk Assessment Register, and reporting on risk status.
- ****Department Managers/Process Owners:**** Responsible for identifying and assessing risks within their operational areas and contributing to risk treatment plans.
- ****All Employees:**** Responsible for reporting identified vulnerabilities or threats.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-PR-002-G: Information Security Risk Assessment Procedure

- IS-CIRQ-PR-003-G: Information Security Risk Treatment Procedure
- IS-CIRQ-F-001-G: Risk Assessment Register
- IS-CIRQ-D-005-G: Risk Treatment Plan (RTP)
- IS-CIRQ-D-006-G: Statement of Applicability (SoA)

****8. Policy Review****

8. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's risk appetite, business environment, or legal/regulatory landscape.